



PORTFOLIO PROFESIONAL

Auditoría de Exposición Digital

Revisión externa, pasiva y documentada de la huella digital pública de una pyme — análisis de un caso real en siete capas.

Dragos C. I. Andrei · Ciberseguridad · Análisis forense digital · Seguridad integral

✉ contacto@controldigitalpymes.es

🐙 github.com/control-digital-pymes

in linkedin.com/in/dragos-cia5

QUIÉN SOY

Perfil

Técnico independiente con formación multidisciplinar en ciberseguridad, análisis forense digital, seguridad integral y electrónica.

Combino conocimiento técnico (SOC, DFIR, hardening, auditoría web) con criterio pericial y una base sólida en lógica, argumentación y pensamiento abstracto. Trabajo orientado a la trazabilidad, la cadena de custodia y la redacción rigurosa de hallazgos.

Peritaje Informático e Informática Forense

UNIR · 450 h · Sobresaliente 9,20

Director de Seguridad

UNIR · 450 h · Sobresaliente 9,50

Técnico Superior en Electrónica

FP de Grado Superior · Málaga

Responsable de Seguridad de la Información

Experiencia real en entorno pyme

Nadie mira el conjunto

La mayoría de pymes no sabe quién controla su dominio, si su correo puede ser suplantado, si su web filtra información o si su analítica mide algo. Cada proveedor revisa su parcela —uno la web, otro el correo, otro la analítica— y nadie revisa el sistema completo.



Activos sin inventariar

Servicios y subdominios expuestos que el propio negocio desconoce.



Correo suplantable

Configuraciones que permiten falsificar la identidad del dominio.



Decisiones a ciegas

Analítica rota o ilegal que distorsiona cada decisión comercial.

Siete capas, un solo sistema

Del dato más fácil de entender al más técnico. Cada capa se analiza y luego se correlaciona con las demás.



1 • Dominio y DNS

Titularidad, vencimientos, resolución, DNSSEC



2 • Correo

Autenticación SPF, DKIM y DMARC



3 • Web pública

Cabeceras, TLS, tecnología expuesta



4 • Credenciales

Exposición en filtraciones conocidas



5 • Suplantación y marca

Typosquatting, certificados, activos huérfanos



6 • Analítica

Medición, cookies y consentimiento



7 • Continuidad

Control de activos y puntos de fallo

Una pyme con tienda online

Auditoría real sobre un comercio electrónico, anonimizada para su publicación. Sector alimentario, producto con denominación de origen, infraestructura WordPress + WooCommerce.

13

HALLAZGOS

2

CRÍTICOS

9

ASPECTOS CORRECTOS

27

EVIDENCIAS CON HASH

Análisis 100% pasivo sobre información pública — sin acceso a sistemas, sin credenciales, sin explotación de vulnerabilidades.

Lo que más importaba



CRÍTICO

Analítica completamente rota

La medición web mezclaba código obsoleto con un identificador moderno incompatible: el negocio llevaba años sin medir nada y decidía a ciegas.



CRÍTICO

Seguimiento sin consentimiento

Un tracker de marketing se cargaba antes de aceptar cookies. El banner era cosmético: informaba, pero no bloqueaba. Riesgo de sanción.

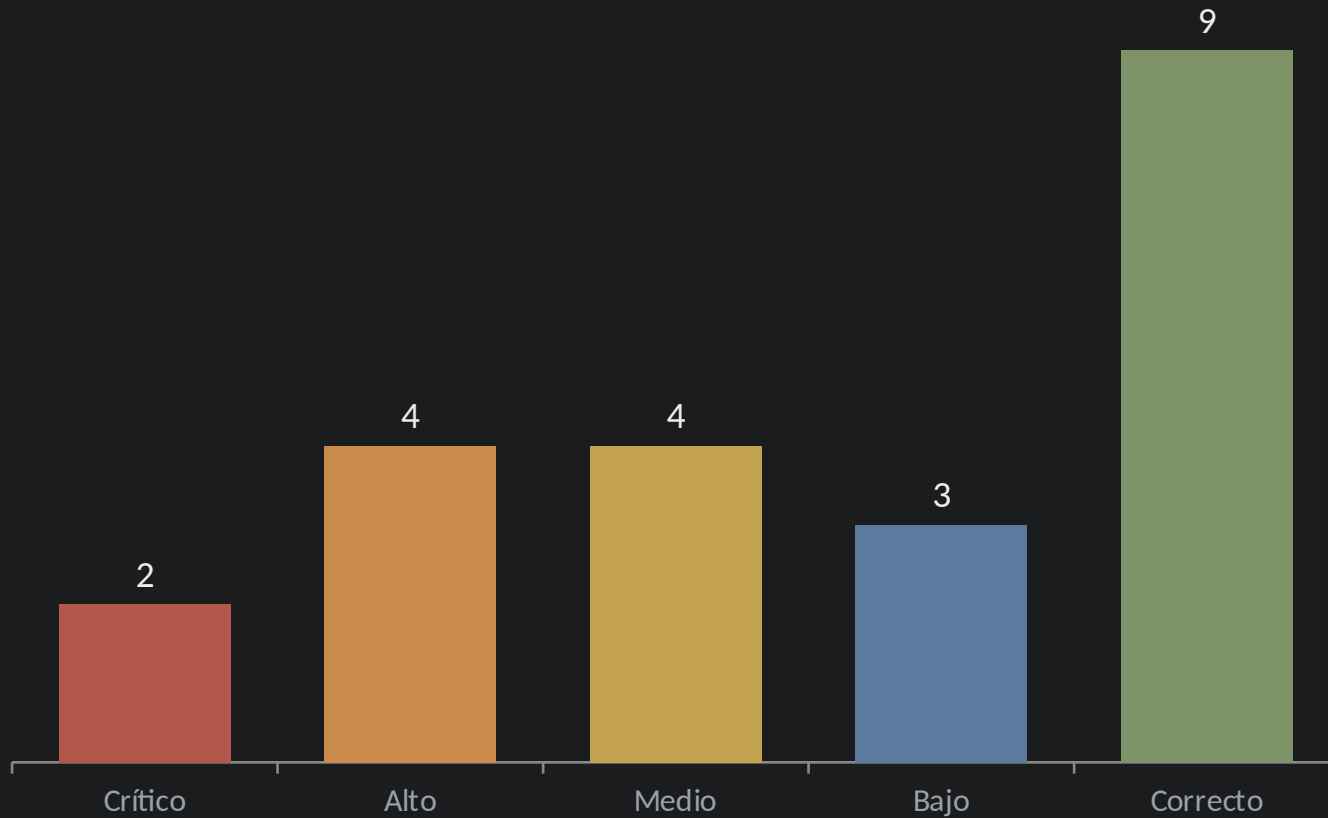


ALTO

Software desactualizado y sistema expuesto

Plugin con historial de vulnerabilidades sin parchear en una tienda con pagos, y un servidor documental expuesto sin inventariar.

Distribución por criticidad



Cómo leerlo

El informe no solo señala problemas. **Nueve aspectos verificados estaban bien hechos**, y se documentan igual que los fallos.

Decir lo que está bien da credibilidad a lo que está mal. Un informe honesto se sostiene aunque lo lea la parte contraria.

El valor está en cruzar las capas

Hallazgos que por separado parecen menores, juntos cuentan una historia y elevan el riesgo real.



Quién hizo el trabajo, y por qué quedó a medias

Configuraciones de alta calidad conviven con olvidos llamativos: trabajo competente sin mantenimiento coordinado, varias manos sin dirección central.



Riesgo de suplantación de marca

Correo falsificable + protección de dominios incompleta + marca reconocida = escenario ideal para un fraude dirigido a sus clientes.



Una tienda que ni mide ni cumple

No mide lo que podría medir legalmente y mide lo que no debería sin permiso, con la página de pago expuesta. La intervención de mayor retorno.

Método y trazabilidad



OSINT pasivo

Solo información pública. No se tocan sistemas ni se prueban credenciales.



Cadena de custodia

Cada evidencia se guarda y se sella con su hash SHA-256, trazable de principio a fin.



Prueba de control

Si una herramienta devuelve vacío, se verifica que funciona antes de concluir.



Límite técnico/legal

Se nombran discrepancias como discrepancias, nunca como infracciones.

Un informe que se entiende y se sostiene

- ✓ Resumen ejecutivo para el dueño del negocio y detalle técnico para su implementador, separados.
- ✓ Hallazgos clasificados por criticidad, con qué se observó, por qué importa y qué hacer.
- ✓ Plan de remediación priorizado por impacto, esfuerzo y coste.
- ✓ Sección «lo que no se ha encontrado»: lo que está bien, verificado.
- ✓ Anexo con la cadena de custodia completa de las evidencias.

Escala de criticidad

-  **Crítico** menos de 7 días
-  **Alto** menos de 30 días
-  **Medio** menos de 3 meses
-  **Bajo** sin urgencia
-  **Correcto** sin acción — lo que está bien

QUÉ SOY CAPAZ DE HACER

Capacidades



Auditoría de exposición digital

Revisión externa en 7 capas de la huella pública de un negocio.



Hardening y seguridad web

WordPress, WAF, cabeceras, TLS, reducción de superficie de ataque.



Auditoría de analítica (GA4/GTM)

Medición correcta, cumplimiento de cookies, detección de fugas.



Análisis forense digital

Adquisición y análisis de memoria, disco y red con cadena de custodia.



Automatización OSINT

Scripts propios de reconocimiento documentados en abierto.



Informes con criterio pericial

Redacción rigurosa, defendible y orientada a la decisión.

HABLEMOS

Trabajo como si todo pudiera acabar en un peritaje.

Esa exigencia es la que hace que un informe sea claro para el cliente y defendible ante cualquiera.

Dragos C. I. Andrei

Control Digital Pymes · Ciberseguridad y auditoría digital para pymes

✉ contacto@controldigitalpymes.es

 github.com/control-digital-pymes

 linkedin.com/in/dragos-cia5

